

SW03 Identitäten

Privatheit, Technologie und Datenschutz

Dozent: Dr. Radwan Eskhita

HSLU Informatik

HS25

Vorlesungsagenda

01

Das Risiko der Re-Identifizierung

Wie Daten trotz Anonymisierung identifiziert werden können

02

Identität

Digitale und physische Identitätskonzepte verstehen

03

Anonymität

Schutz der Identität in digitalen Systemen

04

Pseudonymität

Verwendung von Pseudonymen als Identitätsschutz

05

Pause

Kurze Erholungspause für Fragen und Diskussion

06

Datenschutzziele

Moderne Schutzziele im Datenschutz

07

Zusammenfassung

Wichtige Erkenntnisse und Überblick SW3

Nachtrag zur letzten Vorlesung

Datenschutz Frage

OSINT Tools

HSLU

Firmen-Hotlines: Aufzeichnungspflichten im Rechtsvergleich

Information vs. Einwilligung – was gilt bei der Gesprächsaufzeichnung in der **Schweiz** und in **Deutschland**? Ein praxisorientierter Rechtsvergleich für Compliance-Verantwortliche.



HSLU

CH Schweiz

Firmen-Hotlines in der Schweiz: Information genügt (meistens)

Im Schweizer Recht gilt bei sogenannten **Massengeschäften** ein pragmatischer Ansatz: Eine blosse Information über die Aufzeichnung reicht aus, eine aktive Einwilligung des Kunden ist nicht erforderlich. Doch diese Erleichterung hat klar definierte Grenzen.

HSLU

Das Szenario: Ein alltäglicher Hotline-Anruf

Ein Kunde ruft eine Firmen-Hotline an. Eine automatische Ansage informiert ihn:

> *«Dieses Gespräch wird zu Schulungszwecken aufgezeichnet.»*

Der Kunde muss **nicht aktiv «Ja» sagen** – das Gespräch wird automatisch aufgezeichnet. Kein Tastendruck, keine mündliche Bestätigung. Ist das legal?

✅ In der Schweiz: JA

Unter klar definierten Bedingungen ist dieses Vorgehen rechtmässig und straflos.

HSLU

Die Rechtsgrundlage im Strafrecht

Art. 179 StGB macht das Aufnehmen nicht-öffentlicher Gespräche grundsätzlich strafbar. Doch der Gesetzgeber hat eine praxisrelevante Ausnahme geschaffen:

Art. 179*quinquies* Abs. 1 Bst. b StGB

Aufnahmen sind **straflos**, wenn sie folgende Geschäftsvorfälle betreffen:

- **Bestellungen** und Aufträge
- **Reservationen** und Buchungen
- Ähnliche **Massengeschäfte** des täglichen Geschäftsverkehrs

Begründung des Gesetzgebers

Bei solchen Anrufen ist eine vorherige Einwilligung aus **Praktikabilitätsgründen nicht zumutbar**. Das hohe Anrufvolumen und die standardisierten Abläufe rechtfertigen die Erleichterung.

HSLU

Grenzen dieser Erlaubnis

Die reine Information **ohne aktive Einwilligung** gilt ausschliesslich für Massengeschäfte. Sobald der Anruf über standardisierte Bestellvorgänge hinausgeht, verschiebt sich die rechtliche Bewertung erheblich.

🚫 Reklamationen

Beschwerden und Reklamationsgespräche gehen über einfache Geschäftsvorfälle hinaus – hier ist eine **aktive Einwilligung** erforderlich.

🚫 Komplexe Vertragsverhandlungen

Individuelle Verhandlungen über Vertragskonditionen fallen nicht unter die Massengeschäfts-Ausnahme.

🚫 Marketing & Profiling

Werden Aufnahmen für Marketingzwecke oder Kundenprofiling verwendet, ist die Zweckbindung verletzt und eine **separate Einwilligung** zwingend.

Referenzen: Art. 179*quinquies* Abs. 1 Bst. b StGB (Straflosigkeit bei Geschäftsvorfällen); Botschaft des Bundesrates zum StGB (Erläuterung der «Massengeschäfts»-Ausnahme).

HSLU

KAPITEL 2 DE Deutschland

Firmen-Hotlines in Deutschland: Aktive Einwilligung ist Pflicht

Im Gegensatz zur Schweiz verfolgt Deutschland einen deutlich restriktiveren Ansatz. Weder Strafrecht noch Datenschutzrecht lassen eine automatische Aufzeichnung nach blosser Information zu. Ein **aktives Opt-In** ist zwingend.

HSLU

Dasselbe Szenario – anderes Ergebnis

Ein Kunde ruft eine Hotline an. Dieselbe Ansage informiert über die Aufzeichnung zu Schulungszwecken. Das Gespräch wird automatisch gestartet, ohne dass der Kunde aktiv zustimmen muss.

❌ In Deutschland: NEIN

Dieses Vorgehen ist **rechtswidrig** – sowohl strafrechtlich als auch datenschutzrechtlich.

HSLU

Warum ist das in Deutschland anders?

Zwei Rechtsgebiete greifen ineinander und verbieten die automatische Aufzeichnung ohne explizite Zustimmung:

Strafrecht: § 201 StGB

Das **heimliche oder unbefugte Aufzeichnen** des nicht-öffentlich gesprochenen Wortes ist strafbar. «Unbefugt» bedeutet: ohne **ausdrückliche Erlaubnis** des Gesprächspartners.

Datenschutz: Art. 6 & 7 DSGVO

Die Stimme ist ein **personenbezogenes Datum**. Die Aufzeichnung als Verarbeitung erfordert eine gültige Rechtsgrundlage – das «berechtigte Interesse» (Art. 6 Abs. 1 lit. f) reicht hier **nicht** aus.

Die Aufsichtsbehörden argumentieren klar: Für Zwecke wie Qualitätssicherung oder Schulung gibt es **mildere Mittel** (z.B. stummes Mithören, Testanrufe). Die automatische Aufzeichnung ist daher nicht «erforderlich» im Sinne der Verhältnismässigkeit.

HSLU

Das Prinzip: «Opt-In» statt «Opt-Out»

Die deutsche Rechtslage unterscheidet klar zwischen zwei Modellen – von denen nur eines zulässig ist:

❌ Opt-Out (unzulässig)

Information + *«Wenn Sie nicht einverstanden sind, legen Sie auf.»*

Eine **konkludente Einwilligung** durch Weiterführen des Gesprächs reicht in Deutschland **nicht** aus.

✅ Opt-In (einzig zulässig)

Information + explizite Frage: *«Sind Sie einverstanden? Drücken Sie die 1.»*

Der Kunde muss **aktiv und freiwillig** zustimmen, bevor die Aufzeichnung beginnt.

Referenzen: § 201 StGB; Tätigkeitsbericht der Sächsischen Datenschutz- und Transparenzbeauftragten 2022, S. 99 ff.; DSK-Orientierungshilfe Telefonmedien. Kernaussage: Ein Opt-Out-Verfahren ist bei Hotline-Anrufen unzulässig.

HSLU

VERGLEICH & PRAXIS

Das Wichtigste für Ihre Praxis: Der Vergleich

Die folgende Gegenüberstellung fasst die zentralen Unterschiede zwischen der Schweiz und Deutschland bei der Aufzeichnung von Firmen-Hotline-Gesprächen zusammen.

Kriterium	CH Schweiz	DE Deutschland
Reine Ansage (Info) erlaubt?	Ja, für Massengeschäfte (Bestellungen, Reservationen)	Nein, grundsätzlich verboten
Was ist nötig?	Information über die Aufzeichnung	Aktive Einwilligung (Tastendruck oder mündliches «Ja»)
Rechtsgrundlage	Art. 179 StGB (Ausnahme)	Art. 6 Abs. 1 lit. a DSGVO (Einwilligung)
Risiko bei Verstoss	Strafrechtlich (Art. 179 StGB)	Strafrechtlich (§ 201 StGB) + DSGVO-Bussgeld
Besonderheit	Zweckbindung: Nur für Beweissicherung bei Bestellungen	«Milderes Mittel»-Prinzip verbietet automatische Aufzeichnung

HSLU

Open-Source Intelligence (OSINT)



HSLU

EINFÜHRUNG IN DAS MODUL

OSINT verstehen: Praktische Einblicke

Definition und Anwendungsbereich

OSINT ist das gezielte Sammeln, Verarbeiten und Analysieren von Informationen aus öffentlich zugänglichen Quellen. Es nutzt ausschliesslich Material, das jedermann legal einsehen kann.

OSINT verwandelt verstreute öffentliche Informationen durch strukturierte Analyse in verwertbare Erkenntnisse.

Kernprinzip

Öffentlich zugänglich ≠ harmlos

Zugänglichkeit bedeutet nicht Sicherheit oder mangelnde Sensibilität.

Ihre Relevanz

Zentral für Ihren Datenschutz, Ihre Cybersicherheit und Ihre digitalen Rechte.

HSLU

Öffentliche Daten und der Schutz Ihrer Privatsphäre

Warum „freiwillige“ Datenfreigabe problematisch ist

Oft wird angenommen, dass Online-Datenteilung den Datenschutz aufhebt. Diese Sichtweise übersieht jedoch wichtige Aspekte:

- Plattformregeln und Datennutzung ändern sich ständig.
- Echte Zustimmung fehlt oft.

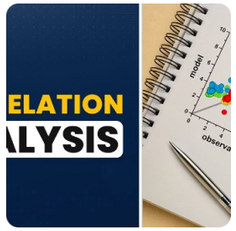
Kontextkollaps: Ein Hauptrisiko für Ihre Privatsphäre

Beispiel: Ein privates Foto kann durch systematische Analyse berufliche Zugehörigkeiten, Bewegungsmuster oder politische Ansichten offenbaren.
Isolierte Datenpunkte, die harmlos erscheinen, können durch Zusammenführung und Korrelation sensible Profile von Personen erstellen.

HSLU

OSINT als Bedrohung für Ihre Privatsphäre

OSINT (Open Source Intelligence) birgt ein Datenschutzrisiko, da scheinbar harmlose Datenpunkte durch systematische Analyse zu umfassenden persönlichen Profilen werden können.



Profilbildung durch Datenkorrelation

Die Zusammenführung von Informationen aus verschiedenen Quellen erstellt detaillierte Profile, die Überzeugungen, Zugehörigkeiten und persönliche Beziehungen offenbaren.



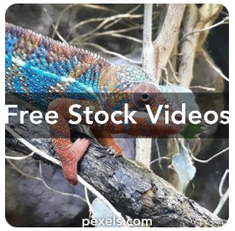
Re-Identifizierung trotz Anonymisierung

Selbst anonymisierte Datensätze können durch Abgleich mit öffentlichen Informationen re-identifiziert werden und machen Anonymisierungsbemühungen zunichte.



Standortverfolgung ohne GPS

Metadaten von Fotos, Check-in-Muster, WLAN-Netzwerk-IDs und Social-Media-Beiträge ermöglichen präzise Standortverfolgung ohne direkte GPS-Daten.



Ableitung von Verhaltensmustern

Die Analyse zeitlicher Muster in Online-Aktivitäten enthüllt tägliche Routinen, Arbeitszeiten, soziale Beziehungen und Lebensstilpräferenzen.

HSLU

TECHNISCHE ANALYSE

Technische Dimensionen von OSINT



Modernes OSINT nutzt technische Fähigkeiten zur automatisierten Sammlung, Verarbeitung und Analyse grosser Mengen öffentlicher Daten, um schnell umfassende Einblicke zu gewinnen.

https://geospy.net
https://www.metadata2go.com/view-metadata
https://intelx.io/tools?tab=username

Methoden für technisches OSINT

Metadaten-Extraktion: EXIF-Daten (Bilder) und Dokumentmetadaten enthüllen Kameramodelle, GPS, Zeitstempel, Software, Autoren und Revisionshistorien.

Umgekehrte Bildsuche: Dienste wie Google Bilder und TinEye zeigen, wo Bilder online erscheinen. So entdecken Sie alternative Benutzernamen, Orte und kontextbezogene Infos.

Benutzernamen-Korrelation: Verknüpfung einzigartiger Benutzernamen über Plattformen hinweg erstellt umfassende digitale Fussabdrücke aus fragmentierten Identitäten.

Automatisierte OSINT-Tools: Software wie Maltego ermöglicht automatisierte Datenerfassung und Beziehungsanalyse im grossen Massstab, was manuell nicht möglich wäre.

HSLU

RECHTLICHE VORGABEN

OSINT und Datenschutz: Ihre rechtlichen Pflichten

OSINT-Aktivitäten sind eng mit Datenschutzgesetzen verknüpft, was Fragen zu den rechtlichen Grenzen der Informationsbeschaffung und -verarbeitung aufwirft. Das revidierte Schweizer Datenschutzgesetz (revDSG) und die EU-Datenschutz-Grundverordnung (DSGVO) bilden hierfür die relevanten Rahmenbedingungen.

Personenbezogene Daten durch Zusammenführung

Informationen gelten als personenbezogene Daten, wenn sie sich auf eine identifizierte oder identifizierbare natürliche Person beziehen. OSINT erzeugt diese oft durch die Kombination öffentlich zugänglicher Daten, die einzeln keine Identifizierung ermöglichen.

Zweckbindung und Verhältnismässigkeit prüfen

Zweckbindung (Artikel 5(1)(b) DSGVO / Artikel 6(3) revDSG): Daten, die für einen Zweck erhoben wurden, dürfen nicht beliebig umfunktioniert werden. OSINT kann dagegen verstossen, wenn öffentlich geteilte Informationen für Überwachung, Profiling oder kommerzielle Auswertung zweckentfremdet werden.

- **Rechtliche Grauzonen verstehen:** Viele OSINT-Aktivitäten bewegen sich in rechtlich unklarem Terrain. Öffentlich verfügbare Informationen können die Privatsphäre verletzen, wenn sie automatisiert und im grossen Massstab gesammelt werden. Gerichte anerkennen zunehmend, dass Legalität allein keine Legitimität gewährleistet. Seien Sie sich dieser Risiken bewusst und handeln Sie proaktiv.

HSLU

Schutzmassnahmen und Präventionsstrategien

Zur Minderung von OSINT-Risiken sind proaktive Massnahmen, die technische Kontrollen, Verhaltensanpassungen und kontinuierliche Überwachung kombinieren, erforderlich. Geschichtete Abwehrmechanismen sind am effektivsten.

01

Bewusste Informationsfreigabe

Überlegen Sie genau, welche Informationen Sie öffentlich teilen. Bedenken Sie mögliche Empfänger und zukünftige Kontexte.

02

Metadaten-Reduktion

Entfernen Sie EXIF-Daten aus Fotos vor dem Teilen. Nutzen Sie Werkzeuge wie ExifTool, MAT2 oder integrierte Plattformfunktionen, um sensible Metadaten zu entfernen.

03

Identitäts-Kompartimentierung

Nutzen Sie separate digitale Identitäten für berufliche, private und sensible Kontexte. Verwenden Sie unterschiedliche Benutzernamen, E-Mail-Adressen und Profile, um Korrelationen zu verhindern.

04

Regelmässige Selbst-OSINT-Audits

Führen Sie regelmässig Selbst-OSINT-Audits durch. Suchen Sie nach Ihrem Namen, Benutzernamen, Telefonnummern und E-Mail-Adressen, um potenzielle Datenlecks zu identifizieren.

Passen Sie regelmässig Datenschutzeinstellungen auf Social-Media-Plattformen an. Nutzen Sie datenschutzorientierte Suchmaschinen und Browser. Bei hohem Risiko sollten professionelle OSINT-Bewertungsdienste in Betracht gezogen werden.

Fall Study

Der "harmlose" Post

Eine trügerische Fassade

1

Der Social-Media-Post

@maxhslu teilt seine Freude: "Endlich am Ziel! Perfekter Start in das Auslandssemester 🎉 #UniLife #Barcelona"

Ein typischer Post junger Erwachsener, spontan, emotional, authentisch. Doch was auf den ersten Blick nach harmloser Begeisterung aussieht, ist eine Goldgrube für OSINT-Analysten.

2

Visueller Anker

Das Foto offenbart mehr als beabsichtigt: Markante Architektur ermöglicht präzise Standortbestimmung, Sonnenstand und Schattenwurf verraten die Tageszeit, Spiegelungen in Fenstern liefern zusätzliche Details über die Umgebung.

Moderne Bilderkennungstools können aus diesen visuellen Hinweisen innerhalb von Sekunden den exakten Aufnahmeort bestimmen – oft auf wenige Meter genau.

3

Identitäts-Fragmente

Der Post liefert konkrete Identifikationsmerkmale: Der Standort in Barcelona ist eindeutig identifizierbar, der Nutzername @max_m lässt sich plattformübergreifend verfolgen, frühere Posts verraten die Heimat-Universität (FH München).

Die zentrale Frage: Was davon wollte der Nutzer wirklich teilen – und was gibt er ungewollt preis?

🎮 OSINT-Challenge: Vom Pixel zur Person

Interaktives Lernspiel

📍 Standort-Analyse (GEOINT)

Tools:

Aufgabe: Analysieren Sie das Foto aus dem Post von @maxhslu

geospy.net (KI-basierte Standortbestimmung)
Google Reverse Image Search
https://osintgeek.de/tools/

Frage: Können Sie den exakten Standort in Barcelona identifizieren?

🔍 Username-Tracking

Aufgabe: Verfolgen Sie @maxhslu über verschiedene Plattformen

Frage: Auf welchen anderen Plattformen ist dieser Nutzer aktiv?

https://namevine.com/#/

Die Kette der Verlinkung

Vom Pixel zur Person

Was als einzelner Post beginnt, entwickelt sich durch systematische OSINT-Methoden zu einem vollständigen Personenprofil. Der Prozess folgt einer präzisen Logik, die öffentlich verfügbare Daten systematisch verknüpft.

Geografische Präzision (GEOINT)

Spezialisierte Tools wie geospy.ai analysieren Fassadenmuster, Strassenverläufe und architektonische Besonderheiten. EXIF-Metadaten in hochgeladenen Fotos liefern GPS-Koordinaten mit einer Genauigkeit von wenigen Metern, Geospy.net….. Reverse Image Search über Google Maps oder Yandex bestätigt die Lokalisierung innerhalb von Minuten.

Kontextuelle Korrelation

Wetterdaten und Schattenanalyse bestätigen den genauen Aufnahmezeitpunkt. Google Maps zeigt Studentenwohnheime im Umkreis von 500 Metern. Öffentliche Universitätsdatenbanken listen Austauschprogramme mit Barcelona. Durch Cross-Referenzierung entsteht ein Zeitfenster und ein wahrscheinlicher Wohnort.

Die Identitäts-Fusion

LinkedIn-Profile mit ähnlichem Nutzernamen liefern den Klarnamen. Fitness-Tracking-Apps wie Strava oder Komoot zeigen regelmässige Laufrouten und damit den tatsächlichen Wohnort. Instagram-Stories, Spotify-Playlists und öffentliche Kommentare vervollständigen das Profil. **Ergebnis: Ein vollständiger Datensatz mit Name, Adresse, Tagesablauf und sozialen Kontakten.**

HSLU

Schritt 1: Benutzernamensuche

5 MINUTEN

Tool: Sherlock

Kostenlose, einfache Benutzernamen-Enumeration über Hunderte von sozialen Netzwerken

Option A: Selbsttest

```
sherlock maxhslu
```

https://apify.com/store/categories

Typische Ergebnisse, die Sie entdecken werden: Have I Been Pwned Creator - Troyhunt

```
[+] GitHub: https://github.com/troyhunt
[+] Twitter: https://twitter.com/troyhunt
[+] Reddit: https://reddit.com/user/troyhunt
[+] HackerNews: Found!
[+] Medium: https://medium.com/@troyhunt
[+] YouTube: Found!
```

Was wir jetzt haben: 5-10 Social-Media-Profile. Dokumentieren Sie für Ihren Selbsttest, wie viele Profile gefunden wurden, welche Sie vergessen hatten und ob alte oder inaktive Konten auftauchten.

HSLU

Schritt 2: Profilbild-Analyse

10 MINUTEN

Profilbild herunterladen

```
# Rechtsklick auf Profilbild → "Bild speichern unter"
# Datei: profilbild.jpg
```

Tool 1: Google Bildersuche (Rückwärtssuche)

01

Navigieren Sie zu https://images.google.com/ - https://tineye.com/

02

Klicken Sie auf das Kamera-Symbol

03

Laden Sie Ihr Profilbild hoch

Was Sie über sich selbst herausfinden können:

- Wo verwenden Sie das gleiche Bild noch?
- Erscheint es auf anderen Plattformen?
- Gibt es ähnliche Bilder von Ihnen?



Beispiel mit einer öffentlichen Person (Troy Hunt): Das Profilbild erscheint auf LinkedIn, GitHub, seiner Website und Rednerlisten von Konferenzen. Zeigt Konsistenz über alle Plattformen hinweg und demonstriert professionelle Wiederverwendung von Bildern.

HSLU

Schritt 3: LinkedIn-Untersuchung

5 MINUTEN

Für den Selbsttest:

01

Öffnen Sie LinkedIn.com

02

Suchen Sie nach Ihrem eigenen Namen

03

Prüfen Sie: Welche Informationen sind öffentlich sichtbar?

Was LinkedIn öffentlich anzeigt (ohne Anmeldung):

- **Name & Berufsbezeichnung:**

  "Security Researcher bei Have I Been Pwned"

- **Aktueller Arbeitgeber/Unternehmen:**

  Oft sichtbar

- **Standort:** Stadt/Region
- **Profilbild:** Vollständig sichtbar

Für eine öffentliche Person (Beispiel):

```
site:linkedin.com "Troy Hunt" security
```

Fragen für Ihren Selbsttest: Ist Ihr Profil auf „öffentlich“ eingestellt? Welche Details sollten privat bleiben? Sind Ihre aktuelle Position/Firma für alle sichtbar?



HSLU

Schnelle Befehlsübersicht

1. Benutzernamensuche

https://www.kali.org/tools/sherlock/

```
sherlock username
```

Findet Social-Media-Profile auf hunderten von Plattformen.

2. EXIF-Daten lesen

```
exiftool image.jpg
```

Extrahiert alle Metadaten, einschliesslich GPS-Koordinaten.

3. Subdomain-Erkennung

```
subfinder -d company.com
```

Findet Subdomains der Zieldomäne.

Wann wird OSINT problematisch?

Legal ✔

- Zweck legitim
- Verhältnismässig
- Transparent
- Mit Rechtfertigung

Illegal ×

- Übermässige Datensammlung
- Zweckänderung ohne Basis
- Massenscraping gegen AGB
- Profiling mit hohem Risiko
- Fehlende Transparenz

Praxisbeispiel: LinkedIn-Profil zur beruflichen Verifikation → in der Regel zulässig bei Due-Diligence-Prüfung (*alle relevanten wirtschaftlichen, rechtlichen und technischen Aspekte des Unternehmens oder Projekts systematisch geprüft werden)*

Verhältnismässigkeit verletzt

Umfassende Social-Media-Analysen für einfache Bewerbung

Zweckentfremdung

Öffentliche Fotos für Profiling oder kommerzielle Zwecke

Informationspflicht missachtet

Betroffene werden nicht informiert trotz rechtlicher Verpflichtung

HSLU

Ethische Grenzen

Rechtlich und erlaubt:

- Öffentlich zugängliche Social-Media-Profile
- Google-Suchen und öffentliche Suchmaschinen
- Öffentliche Archive und Datenbanken
- EXIF-Daten von selbst heruntergeladenen Bildern

Illegal und verboten:

- Passwort-Cracking oder Brute-Force-Angriffe
- Erstellen gefälschter Profile zur Täuschung
- Stalking- oder Belästigungsaktivitäten
- Doxing (Veröffentlichung privater Daten mit böswilliger Absicht)
- Identitätsdiebstahl oder Nachahmung

Grauzone (kontextabhängig):

Diese Aktivitäten können je nach Gerichtsbarkeit, Zweck und Umsetzung legal sein:

- **Aggregation aus vielen Quellen:** Legal, aber potenziell ethisch fragwürdig
- **Kommerzielle Nutzung von Daten:** Kann je nach Datenschutzgesetzen eine Einwilligung erfordern
- **Automatisierte Datenerfassung:** Überprüfen Sie Plattformrichtlinien und lokale Vorschriften

Professioneller Standard: Berücksichtigen Sie stets den Zweck, die Verhältnismässigkeit und den potenziellen Schaden Ihrer Ermittlungen. Nur weil Sie Informationen finden können, heisst das nicht, dass Sie sie auch verwenden sollten.

HSLU

Wichtige Kernbotschaft

"Ein einzelner Benutzername oder ein Profilbild kann innerhalb weniger als einer Stunde mit kostenlosen Tools zu einem vollständigen digitalen Profil führen."

Bewährte Praktiken für digitale Hygiene:



Diverse Benutzernamen

Verwenden Sie unterschiedliche Benutzernamen für verschiedene Plattformen, um plattformübergreifendes Tracking und Korrelationen zu verhindern.



EXIF-/GPS-Daten entfernen

Entfernen Sie Metadaten aus Fotos, bevor Sie sie hochladen, um die Offenlegung von Standorten zu verhindern.

Datenschutzeinstellungen überprüfen

Überprüfen Sie regelmässig die Datenschutzeinstellungen auf allen Plattformen – Standardeinstellungen begünstigen oft die Sichtbarkeit.



Ego-Searching durchführen

Googeln Sie sich regelmässig selbst, um Ihren öffentlichen digitalen Fussabdruck zu verstehen.

Leitfragen SW3

Diese zentralen Fragen werden in der heutigen Vorlesung beantwortet:

- Was umfasst der Begriff „Digitale Identität"?
- Welche Technologien können eingesetzt werden, um die Datensicherheit und den Datenschutz zu gewährleisten?
- Was versteht man unter dem Risiko der Re-Identifizierung?
- Inwiefern unterscheidet sich Pseudonymität von Anonymität?
- Unter welchen Bedingungen könnte die absolute Anonymisierung erreicht werden?
- Welche sind die Schutzziele in der Informationssicherheit?



Agenda

1 **Identität ✔**

Grundlagen digitaler und analoger Identitätskonzepte

2 **Anonymität**

Schutz vor Identifizierung in digitalen Systemen

3 **Pseudonymität**

Verwendung von Pseudonymen als Identitätsschutz

4 **Neue Schutzziele**

Moderne Datenschutzprinzipien und deren Umsetzung

5 **Cases and Illustration**

Praktische Beispiele und Fallstudien

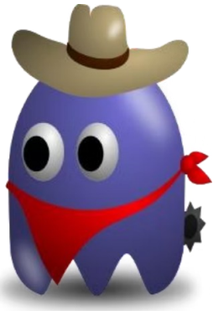
Identität

> „Eine **Identität eines Subjekts** ist eine Menge von Attributwerten, die das Subjekt in einer Menge von Subjekten identifizierbar macht, d. h. von den anderen Subjekten unterscheidet." [1]



- Eine Person kann **viele Identitäten** haben
- Ein Subjekt ist **identifizierbar**, wenn es *innerhalb einer Menge von Subjekten* hinreichend von anderen Subjekten *unterscheidbar* ist
- Die **vollständige Identität** vereint alle Attributwerte der Identitäten eines Subjekts





[1] Ronald Petrlic & Christoph Sorge, Datenschutz (2017)

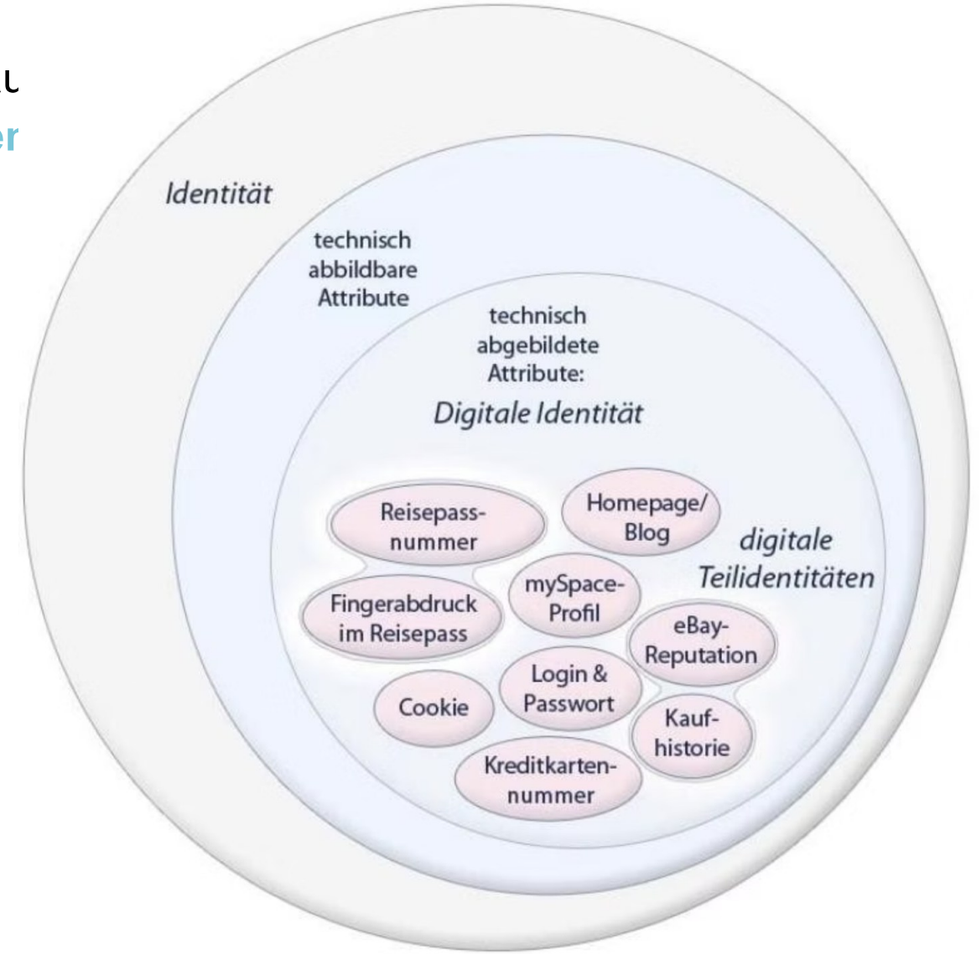
Digitale Identität

Digitale Identitäten repräsentieren die Nutzer in der Informationsgesellschaft. Solche digitalen Identitäten bestehen au technisch abgebildeten Attributen der Nutzer, den **Identitätsdater**

Technisch erfassbare Attribute:

- Passnummer, Führerschein
- Telefonnummer, E-Mail
- Name, Kreditkartennummer
- Bankkontonummer, Blutgruppe
- Geburtsdatum, Frequent Flyer Number
- Benutzernamen, IP-Adressen

Hansen & Meissner (Hrsg.), Verkettung digitaler Identitäten



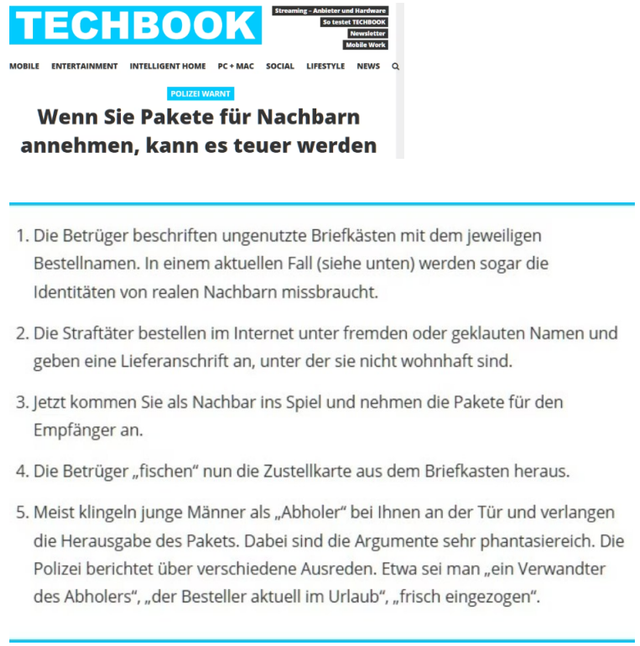
Identitätsdiebstahl

(englisch: identity theft)

Identitätsdiebstahl bedeutet die missbräuchliche Nutzung personenbezogener Daten (der Identität) einer natürlichen Person durch Dritte.

Häufig dient dies dazu, Straftaten zu begehen:

- Kreditkartenbetrug
- Bankbetrug
- Waren- und Leistungskreditbetrug
- Bestellbetrug im Online-Handel



TECHBOOK

Streaming – Anbieter und Hardware
So testet TECHBOOK
Newsletter
Mobile Work

MOBILE ENTERTAINMENT INTELLIGENT HOME PC + MAC SOCIAL LIFESTYLE NEWS

POLIZEI WARNT

Wenn Sie Pakete für Nachbarn annehmen, kann es teuer werden

1. Die Betrüger beschriften ungenutzte Briefkästen mit dem jeweiligen Bestellnamen. In einem aktuellen Fall (siehe unten) werden sogar die Identitäten von realen Nachbarn missbraucht.
2. Die Straftäter bestellen im Internet unter fremden oder geklauten Namen und geben eine Lieferanschrift an, unter der sie nicht wohnhaft sind.
3. Jetzt kommen Sie als Nachbar ins Spiel und nehmen die Pakete für den Empfänger an.
4. Die Betrüger „fischen" nun die Zustellkarte aus dem Briefkasten heraus.
5. Meist klingeln junge Männer als „Abholer" bei Ihnen an der Tür und verlangen die Herausgabe des Pakets. Dabei sind die Argumente sehr phantasiereich. Die Polizei berichtet über verschiedene Ausreden. Etwa sei man „ein Verwandter des Abholers", „der Besteller aktuell im Urlaub", „frisch eingezogen".

Video: Identitätsdiebstahl

Kategorien von Identifikatoren

Identifikatoren

Daten, die eine Person direkt und eindeutig identifizieren können.

- Name
- E-Mail-Adresse
- Sozialversicherungsnummer

Quasi-Identifikatoren

Daten, die allein keine direkte Identifizierung ermöglichen, aber in Kombination mit anderen Daten eine Person identifizierbar machen.

- Geburtsdatum
- Geschlecht
- Postleitzahl

Sensible Identifikatoren

Identifikatoren, die sensible Informationen über eine Person offenbaren und einem besonderen Schutz unterliegen.

- Gesundheitsdaten
- Politische Ansichten
- Biometrische Daten

Kategorien von Identifikatoren

Attribut	Kategorie	Erklärung
Name	Identifikator	Eindeutige direkte Identifizierung
E-Mail-Adresse	Identifikator	Eindeutige direkte Identifizierung
Geburtsdatum	Quasi-Identifikator	Allein nicht eindeutig, aber in Kombination identifizierend
Geschlecht	Quasi-Identifikator	Allein nicht eindeutig, aber in Kombination identifizierend
Postleitzahl	Quasi-Identifikator	Allein nicht eindeutig, aber in Kombination identifizierend
Augenfarbe	Sensibles Attribut	Nicht identifizierend, aber schützenswert
Krankheit Diagnostik	Sensibles Attribut	Nicht identifizierend, aber schützenswert

Das Risiko der Re-Identifizierung

Eine bahnbrechende Studie zeigt, dass **87% der amerikanischen Bevölkerung** eindeutig anhand von nur drei scheinbar harmlosen Attributen identifiziert werden können.

Die Attributwertkombination von **Geburtsdatum, ZIP-Code und Geschlecht** kann somit 216 Millionen Menschen aus einer Menge von 248 Millionen eindeutig zugeordnet werden.

Siehe: "Revisiting the Uniqueness of Simple Demographics in the US Population" - ILIAS



Quelle: Allgemeine Konzepte K-Anonymity, l-Diversity and T-Closeness, Dietmar Hauf

Risikobewertung der Identifizierbarkeit

Demografische Daten und ihre Eindeutigkeit

87%

Eindeutigkeit

{Geburtsdatum, Geschlecht, 5-stelliger PLZ} identifizieren 87% der US-Bevölkerung eindeutig

0.04%

Generalisierung

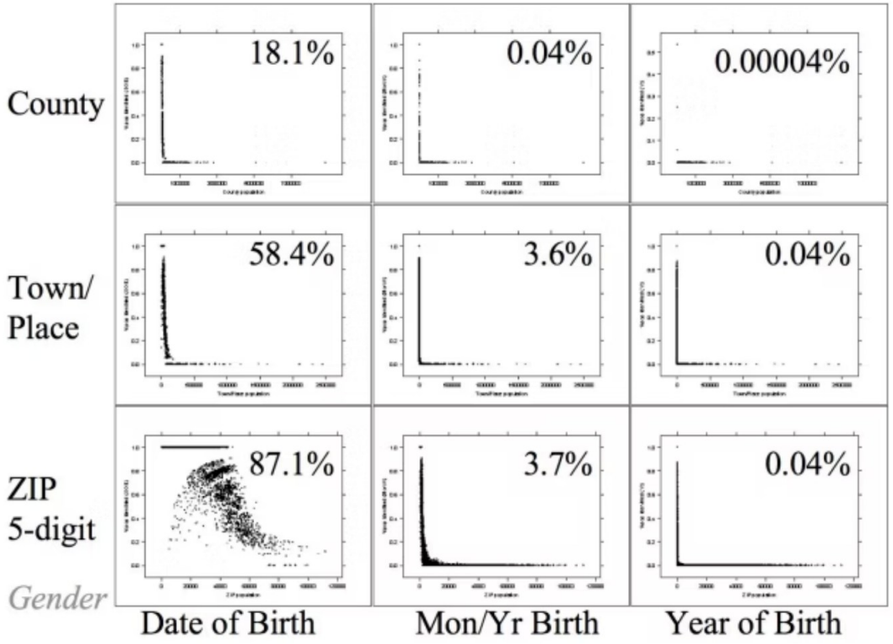
{Geburtsjahr, Geschlecht, 5-stelliger PLZ} reduziert die Identifizierbarkeit auf 0,04%

0.04%

HIPAA-Standards

Die HIPAA Safe Harbor-Bestimmungen erreichen ähnliche Identifizierbarkeit

	5-digit ZIP code	County
Year of birth	0.2%	0.0%
Year and month of birth	4.2%	0.2%
Year, month and day of birth	63.3%	14.8%





Microdata

Date of birth	Gender	Zip Code	Disease
01/02/1992	Male	53715	Heart Disease
19/09/1986	Female	53715	Hepatitis



Vote registration data

Name	Date of birth	Gender	Zip code
Ronald	01/12/1997	Male	53715
Dan	29/03/1946	Male	53715

Re-Identification by Linking

Verknüpfung verschiedener Datensätze

ermöglicht Re-Identifizierung

Identifier	Quasi-identifiers			Sensitive
Name	Date of birth	Gender	Zip Code	Disease
Andre	01/12/1997	Male	53715	Heart Disease
Carol	01/12/1986	Female	53715	Hepatitis
Dan	01/12/1976	Male	53715	Bronchitis
Eve	01/12/1994	Female	53715	Broken arm
Ellen	01/12/1992	Female	53715	Flu
Eric	01/12/1991	Male	53715	Flu

Always **removed** before release

Can be used for **linking** **anonymized dataset** with other datasets

Used for **research** purposes

Quelle: Destrinet, Thomas Van den BosscheWird in den kommenden Wochen wieder erklärt

Praktisches Beispiel – Re-Identifizierung

Datensatz A: Gesundheitsdaten (anonymisiert)

ID	Alter	Geschlecht	PLZ	Krankheit
1	34	weiblich	12345	Diabetes
2	45	männlich	23456	Bluthochdruck
3	29	weiblich	34567	Asthma

Datensatz B: Wählerverzeichnis (öffentlich)

Name	Alter	Geschlecht	PLZ
Anna	34	weiblich	12345
Bernd	45	männlich	23456
Claudia	29	weiblich	34567

Schritt-für-Schritt-Re-Identifikation

01

Kombination der Attribute

Eine 34-jährige Frau mit PLZ 12345 leidet an Diabetes

02

Re-Identifikation

Im Wählerverzeichnis passt nur Anna auf diese Beschreibung

03

Verknüpfung

Wir wissen jetzt, dass Anna Diabetes hat

Original dataset

Identifier	Quasi-identifier			Sensitive
id	**Zip Code**	**Age**	**Nationality**	**Disease**
1	13053	28	Russia	Cardiac
2	13066	29	US	Cardiac
3	13068	21	Japan	Infectious
4	14853	41	US	Infectious
5	14853	50	India	Cancer
6	14853	47	US	Cardiac
7	13053	37	India	Cardiac
8	13068	39	US	Cancer
9	13068	31	US	Infectious



3-anonymous dataset

Identifier	Quasi-identifier			Sensitive
id	**Zip Code**	**Age**	**Nationality**	**Disease**
1	130**	<30	*	Cardiac
2	130**	<30	*	Cardiac
3	130**	<30	*	Infectious
4	1485*	>40	*	Infectious
5	1485*	>40	*	Cancer
6	1485*	>40	*	Cardiac
7	130**	3*	*	Cardiac
8	130**	3*	*	Cancer
9	130**	3*	*	Infectious

Equivalence class

Das Risiko der Re-Identifizierung – ARX Beispiel

Das ARX Data Anonymization Tool demonstriert die Herausforderungen bei der Datenanonymisierung:

Einige Folien in dieser Präsentation wurden aus den folgenden Quellen entnommen:- Thomas Van den Bossche, Destrinet, ARX Tool

Dash Workshop Datei

Das Risiko der Re-Identifizierung – ARX Beispiel

Determining threshold value

- Theshold helps to **interpret re-identification probability**
- **actual risk > threshold ➔ unacceptable!**

- In practice:
  - Health data: minimal equivalence class size of **5**
  - Threshold probability = **0.2**

Visualisierung der Risikobewertung durch das ARX-Tool:

- Risk = probability to **identity single record**
- Not known a priori **who** intruder will re-identify

worst-case assumption
person to re-identify is in
smallest equivalence class

Overall probability of re-identification = $1/2$

2-anonymity DB

Identifier	Quasi-identifier			Sensitive
id	**Zip Code**	**Age**	**Nationality**	**Disease**
1	130**	<30	*	Cardiac
2	130**	<30	*	Cardiac
3	130**	<30	*	Infectious
4	1485*	>40	*	Infectious
5	1485*	>40	*	Cancer
6	1485*	>40	*	Cardiac
7	1485*	>40	*	Infectious
7	130**	3*	*	Cancer
8	130**	3*	*	Infectious

2

Quelle: Destrinet, Thomas Van den Bossche – Seite 63

Re-Identifizierung

Definition

Aufhebung einer zuvor durchgeführten Pseudonymisierung oder Anonymisierung von Daten.

Identitätsdaten

Name, Adresse, Personalnummer

Demografische Daten

Geschlecht, Alter, Nationalität

Analysedaten

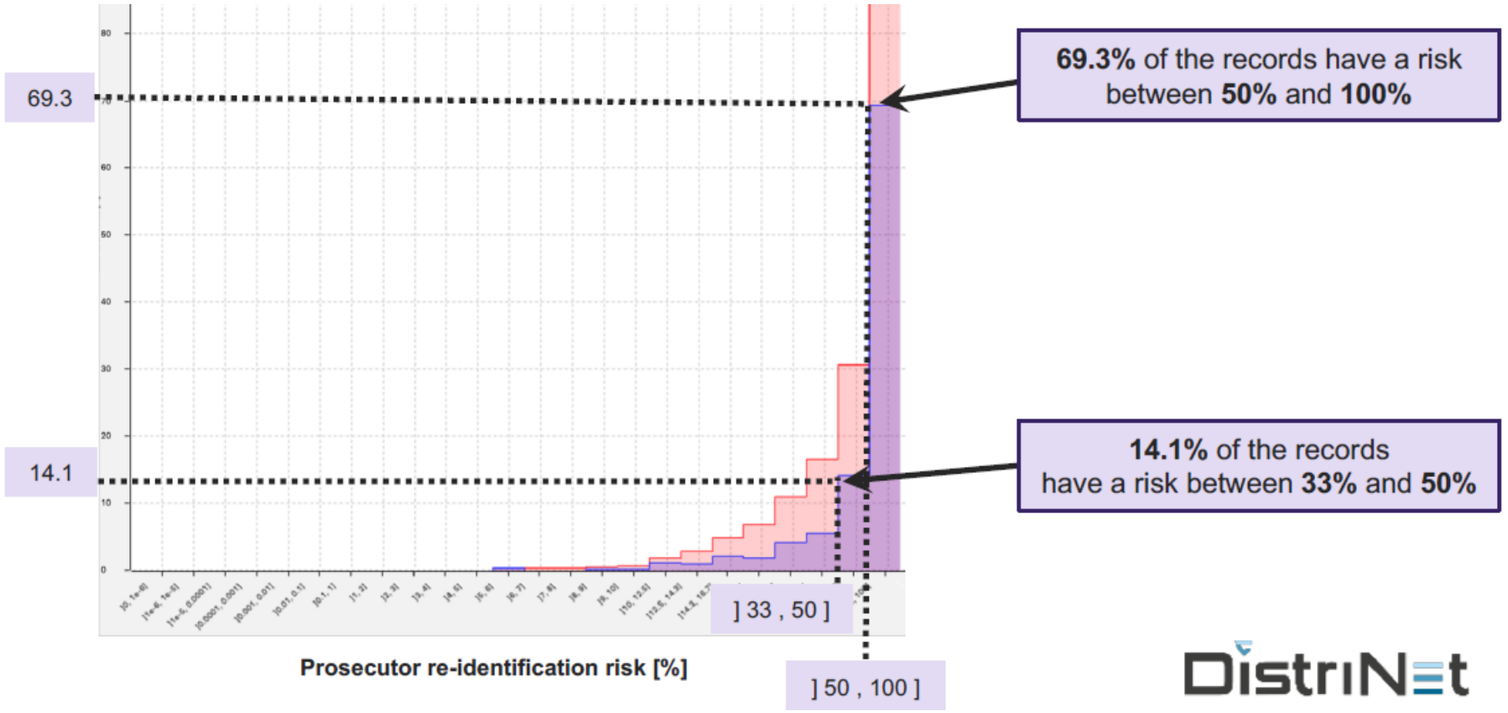
Krankheiten, Gewohnheiten

Der Grad der Anonymität hängt ab von der **Entropie** – wie schwer es für einen potenziellen Angreifer ist, anhand der verfügbaren Informationen eine Person eindeutig zu identifizieren oder persönliche Details über sie abzuleiten.

Das Risiko der Re-Identifizierung – ARX-Beispiel

Praktische Demonstration der Identifizierungsrisiken mit dem ARX Data Anonymization Tool:

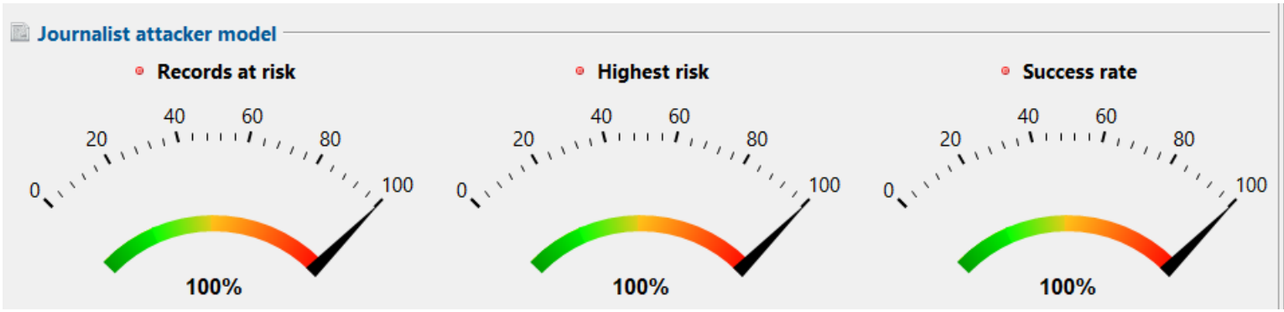
Das Tool zeigt anschaulich, wie scheinbar anonyme Datensätze durch Kombinationen von Attributen re-identifiziert werden können.

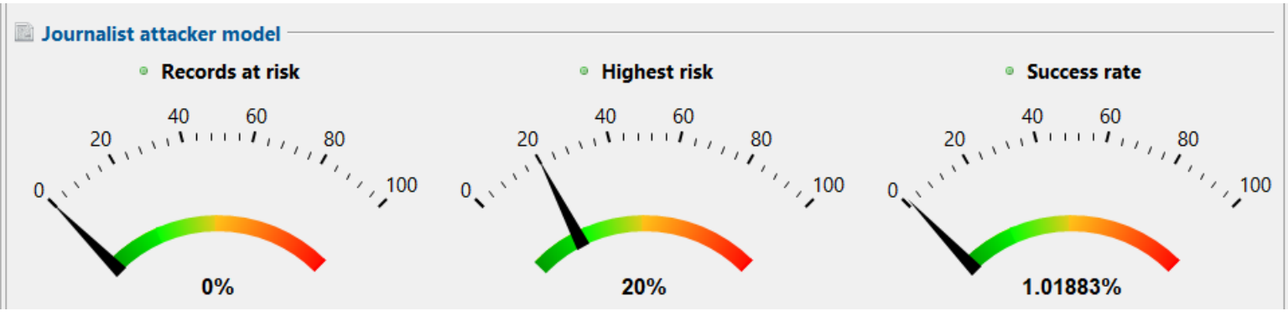


Dash Workshop Datei

Quelle: Destrinet, Thomas Van den Bossche, **Seite 65**

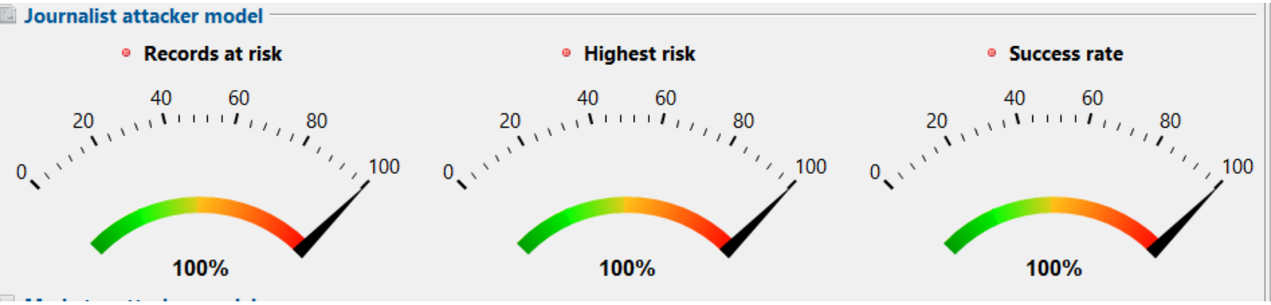
Test: Eine Erhöhung des Anonymity-Wertes von 5 auf 20 reduziert das Highest Risk von 20 % auf 5 %.

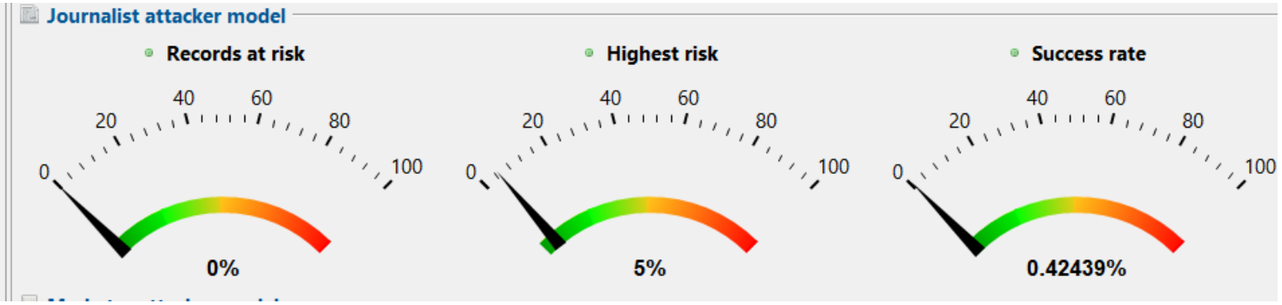




Privacy models | Population | Costs and benefits

Type	Model	Attribute
(k)	20-Anonymity	





Dash Workshop Datei



HSLU Lucerne University of Applied Sciences and Arts

Aufgabe

Praktische Übung

Sie erhalten zwei Tabellen:

1. **Anonymisierte Tabelle:** Enthält pseudonymisierte oder aggregierte Daten
2. **Referenztabelle:** Enthält Originaldaten mit Identitätsinformationen

Ihre Aufgabe ist es, zu überprüfen, in wie vielen Fällen eine Re-Identifizierung manuell möglich ist.

ILIAS – SW03 - Re-Identifizierung in Datensätzen

Weitere Beispiele: Fall zur Veranschaulichung – ILIAS

Agenda

1 **Identität**

Grundlagen digitaler und analoger Identitätskonzepte

2 **Anonymität ✔**

Schutz vor Identifizierung in digitalen Systemen

3 **Pseudonymität**

Verwendung von Pseudonymen als Identitätsschutz

4 **Neue Schutzziele**

Moderne Datenschutzprinzipien und deren Umsetzung

5 **Zusammenfassung**

Wichtige Erkenntnisse und Wiederholung

Anonymität

> Ein Subjekt ist *anonym gegenüber einem Angreifer*, wenn der Angreifer das Subjekt in einer Menge von Subjekten (der Anonymitätsmenge) nicht hinreichend identifizieren kann.
>
> Ronald Petrlic & Christoph Sorge, Datenschutz (2017)

Die Identität einer oder mehrerer an einem anonymen Vorgang beteiligte Instanzen ist nicht bestimmbar, weil sie entweder:

Nichtbekanntsein

Den anderen beteiligten Instanzen nicht bekannt ist

Nichtgenanntsein

Gegenüber anderen Instanzen nicht in Erscheinung tritt

Namenlosigkeit

Innerhalb des anonymen Vorgangs ohne erkennbaren Namen agiert

Anonymität hängt vom Szenario ab und es gibt verschiedene Abstufungen der Anonymität.

Hansen & Meissner (Hrsg.), Verkettung digitaler Identitäten, 2007.

Anonymität

Arten der Anonymität

- **Sender- und Empfängeranonymität** ☞ Identität
- **Ortsanonymität** ☞ Attribute



Anonymisierung

Der Prozess, um Anonymität zu erreichen – personenbezogene Daten derart zu verändern, dass Einzelangaben nicht mehr oder nur sehr schwierig einer bestimmten oder bestimmbaren natürlichen Person zugeordnet werden können.

Hansen & Meissner (Hrsg.), Verkettung digitaler Identitäten, 2007.



Nicht einfach anonym zu bleiben

Netzwerk IP (Ort) kann deinen Ort verraten

Diese Information kann auch für lange Zeit bei ISP gespeichert werden

Web Apps können verfolgt werden

- Cookies, Flash Cookies, E-Tags
- HTML5 Storage
- Skype, Google Voice
- Browser Fingerprinting

Aktivitäten können dich identifizieren

- Welche Websites und Apps benutzt
- Trends – Website-Arten
- Gesuchte Stichwörter

Absolute Anonymisierung

Eine **absolute Anonymisierung** liegt vor, wenn niemand in der Lage ist, den Personenbezug wiederherzustellen. Dies kann beispielsweise durch die Löschung von Identifikationsmerkmalen in einer Datenbank erfolgen.

Da der Verantwortliche das Zusatzwissen Dritter nicht kennen kann, muss er strukturell sicherstellen, dass unabhängig von möglichem Zusatzwissen keine De-Anonymisierung mehr möglich ist.

Kann eine Identifizierung der betroffenen Person nur mit einem **unverhältnismässig grossen Aufwand** an Zeit, Kosten und Arbeitskraft erfolgen, handelt es sich um eine *faktische Anonymisierung*.

Bei einer absoluten oder faktischen Anonymisierung sind die Datenschutzgesetze nicht anzuwenden.

(PRIVACY UND BIG DATA, Fraunhofer 2020)

Agenda

1 **Identität**

Grundlagen digitaler und analoger Identitätskonzepte

2 **Anonymität**

Schutz vor Identifizierung in digitalen Systemen

3 **Pseudonymität ✔**

Verwendung von Pseudonymen als Identitätsschutz

4 **Neue Schutzziele**

Moderne Datenschutzprinzipien und deren Umsetzung

5 **Zusammenfassung**

Wichtige Erkenntnisse und Wiederholung

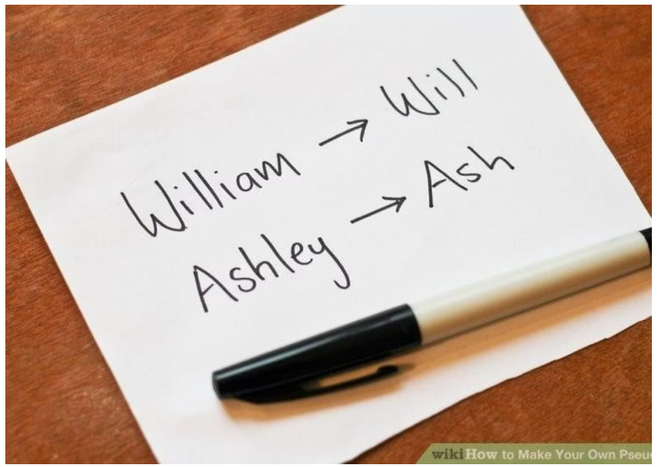
Pseudonymität

Definition

> „Ein **Pseudonym** ist ein Identifikator für ein Subjekt ungleich dem realen Namen des Subjekts." [1]

Beispiele für Pseudonyme:

- **DJ Ötzi** (Künstlername)
- **so5467642** (technisches Pseudonym)
- **c0ba40a69db16e3dde83cc634513fd13** (Hash-Wert)



Pseudonymität ist erreicht, wenn das Subjekt durch ein Pseudonym bezeichnet ist und ein Angreifer nicht hinreichend auf den realen Namen des Subjekts schliessen kann.



[1] Ronald Petrlic & Christoph Sorge, Datenschutz (2017)

Bildquelle: https://www.wikihow.com/Make-Your-Own-Pseudonym

Pseudonymität

Pseudonymisierung verändert personenbezogene Daten mittels einer **Zuordnungsvorschrift** derart, dass Einzelangaben ohne Kenntnis oder Nutzung der Zuordnungsvorschrift nicht mehr einer natürlichen Person zugeordnet werden können.

☞ lässt sich **rückgängig** machen!

Beispiel: Ersetze in einer Datenbank jedes Auftreten eines Namens durch eine (für diesen Namen jeweils gleichbleibende) Nummer. Die Zuordnungsvorschrift ordnet dann einfach jeder Nummer wieder den dazu passenden Namen zu, auch *Korrespondenztabelle* genannt.

☞ Ist das ausreichend?



Pseudonymität

Originaldatensatz

ID	Name	Postleitzahl	Alter	Geschlecht	Familienstand	Retake
1	Daniel Keller	8605	33	M	ledig	nein
2	Elias Amherd	8612	31	M	vh.	nein
3	Clara Zimmermann	6001	29	W	vh.	nein
4	Anny Frey	6012	28	W	ledig	ja
5	Barbara Zweistein	6062	30	W	vh.	nein
6	Fabio Teufel	8512	24	M	ledig	ja

Zuordnungsvorschrift - PII

Name	Pseudonym
Daniel Keller	bb75e0cb68b73634286e02779282ca48
Elias Amherd	6cd19f55811cd32ad7d0d60da6680a7b
Clara Zimmermann	f4975611e9e437c7cac1a5eb2486d109
Anny Frey	b7772a45020d3f727abe1b0658ec6b7c
Barbara Zweistein	da797ac52424e828658109dd3ab48462
Fabio Teufel	27b862a80e54281ddeda61522668199c



Pseudonymität

Pseudonymisierter Datensatz

ID	Pseudonym	Postleitzahl	Alter	Geschlecht	Familienstand	Retake
1	bb75e0cb68b73634286e02779282ca48	8605	33	M	ledig	nein
2	6cd19f55811cd32ad7d0d60da6680a7b	8612	31	M	vh.	nein
3	f4975611e9e437c7cac1a5eb2486d109	6001	29	W	vh.	nein
4	b7772a45020d3f727abe1b0658ec6b7c	6012	28	W	ledig	ja
5	da797ac52424e828658109dd3ab48462	6062	30	W	vh.	nein
6	27b862a80e54281ddeda61522668199c	8512	24	M	ledig	ja

☞ Ist die Identität der Subjekte ausreichend geschützt?

Klassifikation von Pseudonymen

Erzeugungsart (wie erzeugt man sie überhaupt)

Deterministisch

Schlüsselabhängige, Einweg- oder Hash-Funktion aus invarianten Daten (z.B. Identitätsdaten)

Eine Hash-Funktion auf E-Mail-Adressen erzeugt bei jeder Anwendung derselben Hash-Funktion auf dieselbe E-Mail-Adresse immer denselben Hash-Wert.

Willkürlich

Nach einem festen Einweg-Algorithmus vom Benutzer aus einem Geheimnis (z.B. Passphrase)

Passphrase "Sonnenschein123" verwendet, um ein Pseudonym zu erstellen, und jedes Mal, wenn dieselbe Passphrase eingegeben wird, wird dasselbe Pseudonym erzeugt.

Zufällig

Frei gewählt oder nach einem Zufallsverfahren

Zusammensetzen von Wörtern: Sie können zwei oder mehr Wörter kombinieren, z.B. den Namen eines Tiers mit einer Stadt verbinden.

Anonym oder Pseudonym

Der Unterschied zwischen anonymen und pseudonymen Daten liegt darin, dass bei pseudonymen Daten ausserhalb der Zugriffsmöglichkeiten des Verantwortlichen grundsätzlich eine Zuordnungsmöglichkeit besteht oder bestehen könnte, bei anonymen Daten hingegen für niemanden eine Zuordnungsmöglichkeit vorhanden ist.

(PRIVACY UND BIG DATA, Fraunhofer 2020)



Anonym oder Pseudonym

Beispieldatensatz

~~Vorname~~	~~Nachname~~	Geschlecht	Geb.-Datum	PLZ
~~Heike~~	~~Richter~~	w	11.05.1983	10115
~~Jan~~	~~Schröder~~	m	03.12.1965	10115
~~Hugo-Egon~~	~~Meyer~~	m	27.08.1977	10178

Bewertung: Sind diese Daten anonym oder pseudonym?

Anonym oder Pseudonym

Vorname	Nachname	Geschlecht	Geb.-Datum	PLZ
Heike	Richter	w	11.05.1983	10115
Jan	Schröder	m	03.12.1965	10115
Hugo-Egon	Meyer	m	27.08.1977	10178

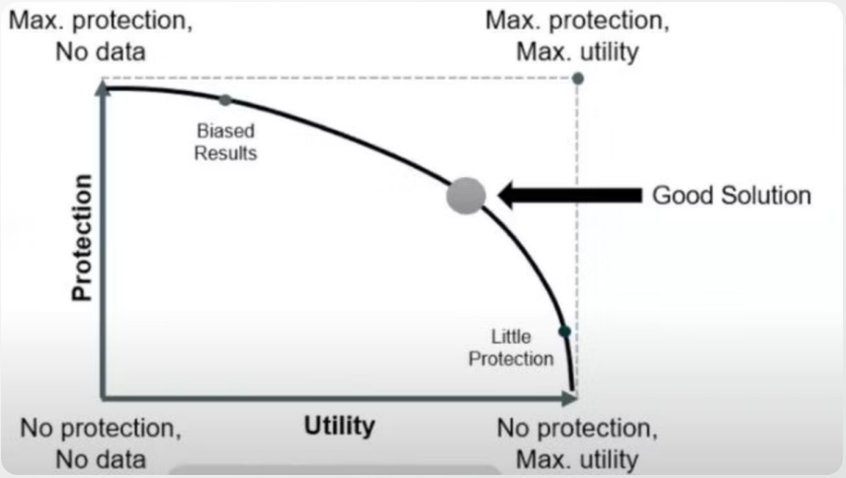
⊗ Es ist teilweise möglich, eine Re-Identifikation der Daten aus der Tabelle durchzuführen: Nur Frau Richter und Herr Schröder wohnen in einem Bereich, dessen PLZ mit „1011" beginnt, und durch die Geschlechtsangabe ist eine eindeutige Zuordnung möglich. Die Daten sind also nicht als anonyme Daten anzusehen, sondern als **pseudonyme Daten**.

☞ lässt sich rückgängig machen!

Man soll trotzdem folgendes beachten:

Auch bei scheinbar anonymisierten Daten muss die Möglichkeit einer Re-Identifizierung durch Zusatzwissen und Verknüpfung mit anderen Datenquellen berücksichtigt werden.

Trade-off: Je mehr Daten für Analysezwecke verfügbar gemacht werden, desto höher wird das Risiko der Re-Identifizierung - selbst bei anonymisierten Datensätzen.



Agenda

1 **Identität**

Grundlagen digitaler und analoger Identitätskonzepte

2 **Anonymität**

Schutz vor Identifizierung in digitalen Systemen

3 **Pseudonymität**

Verwendung von Pseudonymen als Identitätsschutz

4 **Neue Schutzziele** ✔

Moderne Datenschutzprinzipien und deren Umsetzung

5 **Zusammenfassung**

Wichtige Erkenntnisse und Wiederholung



Datensicherheit und Datenschutz

Datensicherheit

- **Geschützt:** Hardware, Software, Daten
- **Gefahr:** Verlust, Zerstörung und Missbrauch durch Unbefugte

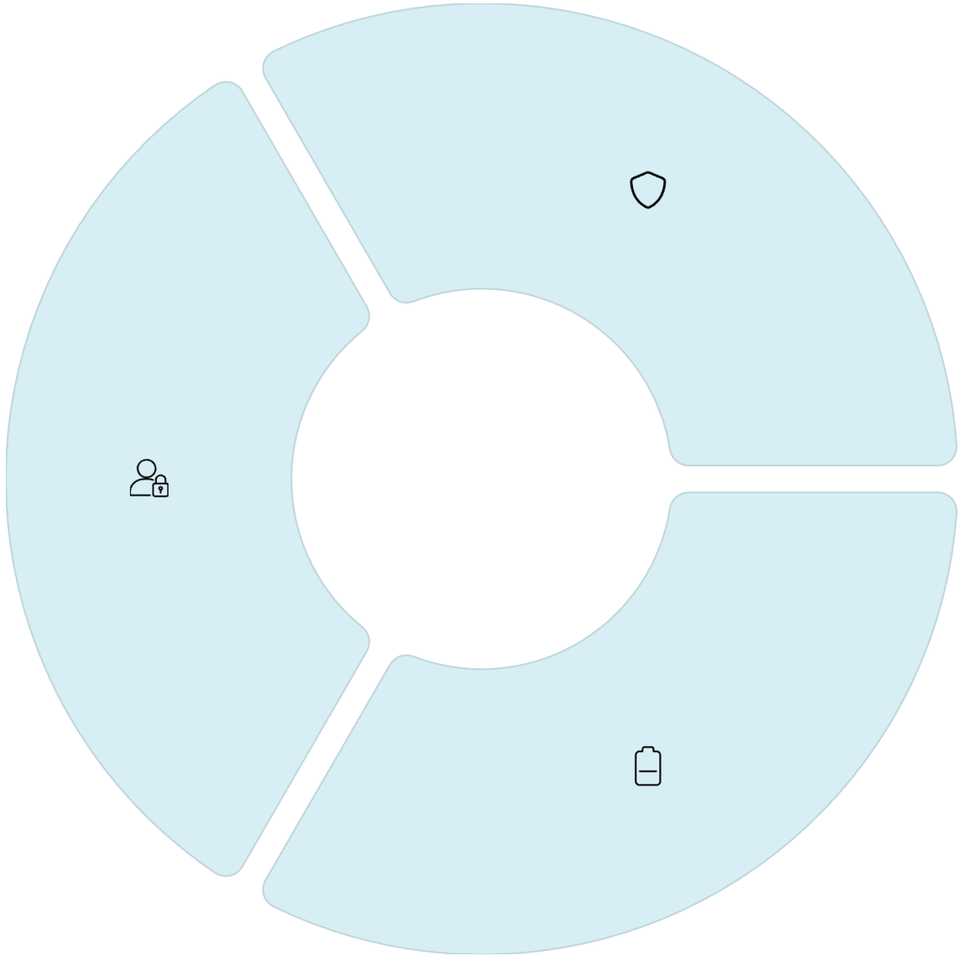
Datenschutz

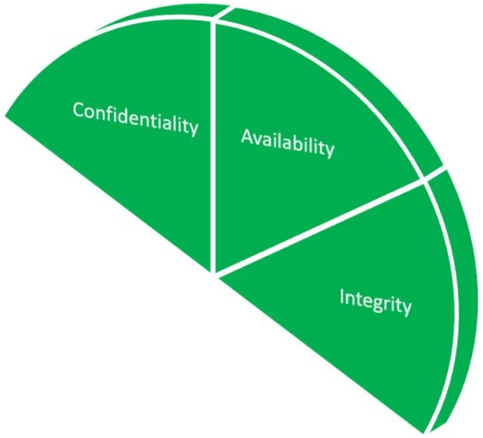
- **Geschützt:** Natürliche Personen
- **Gefahr:** Verletzung von Persönlichkeitsrechten

Aus: Viehweger, B. (2008). Datenschutz/Datensicherheit.

Schutzziele IT Sicherheit

Grundlagen





Confidentiality

Integrity

Availability

Vertraulichkeit

Datenschutz-Schutzziele

Transparenz

Die Verarbeitung von personenbezogenen Daten kann mit zumutbarem Aufwand nachvollzogen, überprüft und bewertet werden

Nichtverkettbarkeit

Personenbezogene Daten können nicht oder nur mit unverhältnismässig hohem Aufwand für andere Zwecke verwendet werden



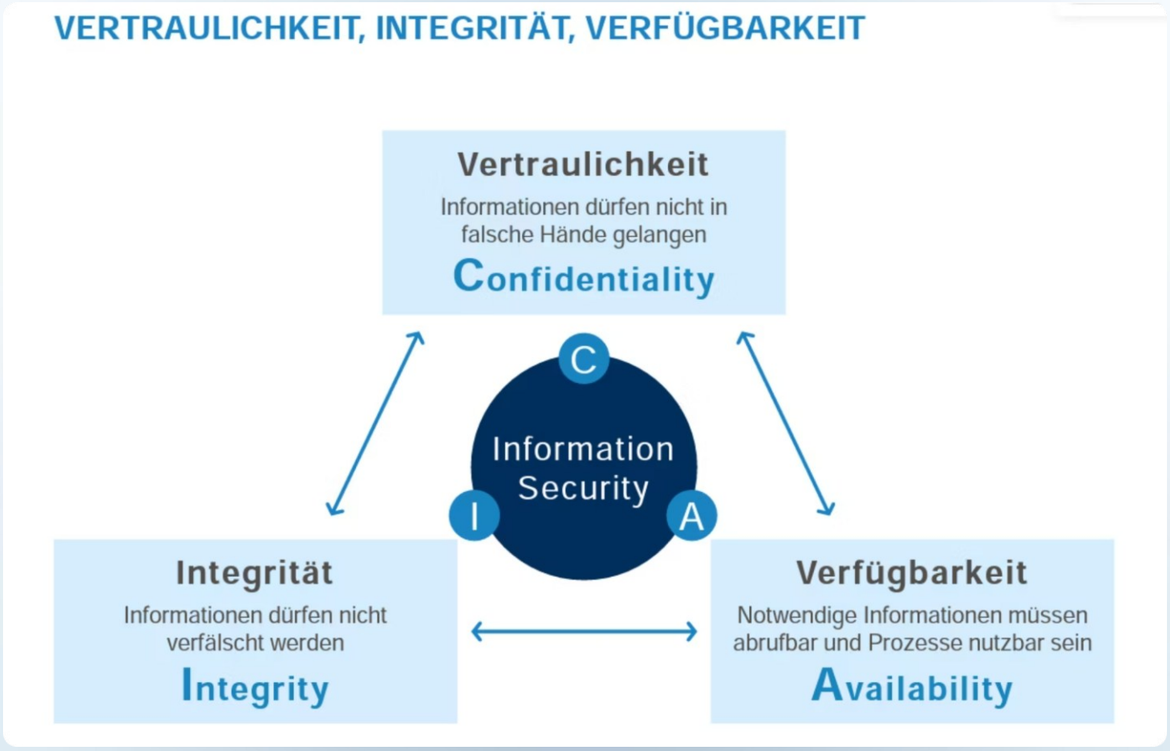
Intervenierbarkeit

Verfahren ermöglichen den Betroffenen die wirksame Ausübung ihrer Datenschutzrechte

Schutzziele IT Sicherheit

CIA-Triade Visualisierung

Die drei Grundpfeiler der IT-Sicherheit arbeiten zusammen, um einen umfassenden Schutz zu gewährleisten.



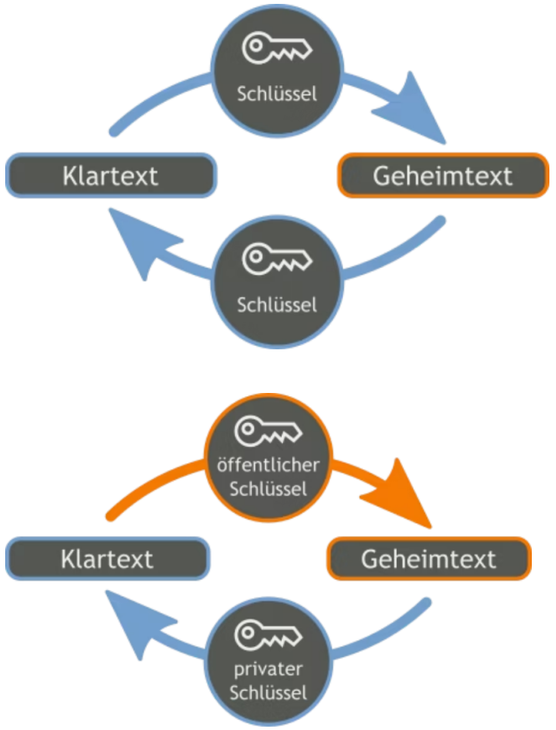
Schutzziele IT Sicherheit

Confidentiality - Vertraulichkeit

Vertraulichkeit (Confidentiality): Sicherstellung, dass Informationen nur von dazu autorisierten Personen (oder allgemeiner: Subjekten) gelesen werden können.

Mittel zur Gewährleistung:

- **Verschlüsselung**
  - Symmetrische Verschlüsselung: Ein Schlüssel zur Ver- und Entschlüsselung
  - Asymmetrische Verschlüsselung: öffentlicher Schlüssel (Verschlüsselung), privater Schlüssel (Entschlüsselung)
- **Zugriffskontrolle** – Verhindern des Zugriffs auf Daten
- **Sicheres Löschen/Entsorgungskonzept**



Schutzziele IT Sicherheit

Integrität

Integrität (Integrity): Sicherstellung der Korrektheit und Vollständigkeit von Informationen und Verarbeitungsmethoden.

Verschiedene Integritätszustände nach:

Korrekter Inhalt

Sachverhalte der realen Welt werden korrekt abgebildet, z.B. sichergestellt durch Integritätsbedingungen

Unmodifizierter Zustand

Nachrichten werden unverändert zugestellt und Programme/Prozesse laufen wie beabsichtigt

Erkennung von Modifikation

Unerwünschte Modifikationen, die nicht verhindert werden können, werden zumindest erkannt

Temporale Korrektheit

Relevante zeitliche Bedingungen beim Nachrichtenaustausch werden eingehalten, z.B. Reihenfolgen oder maximale Verzögerungszeiten

[1] Biskup: Security in Computing Systems: Challenges, Approaches and Solutions. 2009, S. 41–45.

Schutzziele der IT-Sicherheit

Availability - Verfügbarkeit

Verfügbarkeit (Availability): Sicherstellung, dass Benutzer (allgemeiner: Subjekte) Zugriff auf Informationen/System haben

Verfügbarkeit	Minimale erwartete Betriebszeit [Stunden]	Maximale erlaubte Ausfallzeit [Stunden]	Maximale erlaubte Ausfallzeit [Minuten]
99%	8672,4	87,6	5256
99,9%	8751,24	8,76	525,6
99,95%	8755,62	4,38	262,8
99,99%	8759,124	0,876	52,56
99,999%	8759,9124	0,0876	5,256
100%	8760	0	0

$$\text{Verfügbarkeit} = \frac{\text{Gesamtzeit-Gesamtausfallzeit}}{\text{Gesamtzeit}}$$





Schutzziele der IT-Sicherheit

Verfügbarkeit

Massnahmen zur Sicherung der Verfügbarkeit:

Redundanz

Mehrfache Ausführung kritischer Komponenten zur Ausfallsicherheit

Backups

Regelmässige Datensicherungen zur Wiederherstellung bei Datenverlust

Diversität

Vermeiden von Single Points of Failure durch verschiedene Technologien

Neue Datenschutz Schutzziele

Transparenz

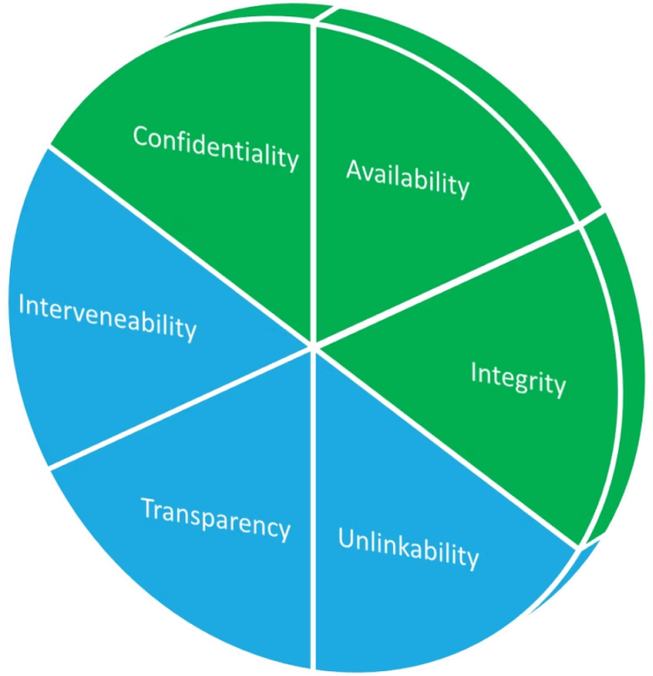
Die Verarbeitung von personenbezogenen Daten kann mit zumutbarem Aufwand nachvollzogen, überprüft und bewertet werden. (Recht zu erfahren, wie ihre personenbezogenen Daten verwendet werden)

Nicht-Verkettbarkeit

Personenbezogene Daten können nicht oder nur mit unverhältnismässig hohem Aufwand für einen anderen als den ausgewiesenen Zweck erhoben, verarbeitet und genutzt werden. (z.B Zweckbindung)

Intervenierbarkeit

Die Verfahren sind so gestaltet werden, dass sie den Betroffenen die Ausübung der ihnen zustehenden Rechte wirksam ermöglichen. (Datenschutzrechte auszuüben)



Datensicherheit und Datenschutz

Transparenz

Transparenz: Die Verarbeitung von personenbezogenen Daten erfolgt in einer […] nachvollziehbaren Weise.

- Z.B. Normiert in Art. 5 Abs. 1 lit. a DSGVO
- Nachvollziehbarkeit für den Betroffenen, Betreiber, Kontrollinstanzen

Massnahmen:

Dokumentation

Verarbeitungstätigkeiten, Tests, Freigaben, interne/externe Verträge

Auf Datenebene

Protokollierung der Datenverarbeitung, Zugriffe und Änderungen

Auf Systemebene

Dokumentation der eingesetzten Systeme, ihrer Konfiguration und Veränderungen sowie administrativen Eingriffen

Datensicherheit und Datenschutz

Unverkettbarkeit

Unverkettbarkeit: Personenbezogene Daten dürfen nicht für einen anderen als den ausgewiesenen Zweck erhoben, verarbeitet und genutzt werden.

Weiterverarbeitung nur unter engen Voraussetzungen (beispielsweise fortdauernde Einwilligung des Betroffenen)

Massnahmen:

Organisatorische Trennung

Einschränkung von Verarbeitungs-, Nutzungs- und Übermittlungsrechten, Trennung nach Organisations-/Abteilungsgrenzen

Auf Datenebene

Anonymisierung, Pseudonymisierung oder Nicht-Erhebung identifizierter Daten

Auf Systemebene

Einrichtung entsprechender Zugriffsrechte oder Verarbeitung auf unterschiedlichen Systemen

Unverkettbarkeit

Definition

Zwei (oder mehrere) betrachtete Objekte (wie Nachrichten, Personen etc.) in einem System sind **unverkettbar**, wenn ein Angreifer nicht hinreichend sicher feststellen kann, ob zwischen diesen Objekten **eine Beziehung** besteht oder nicht.

Beispiel: Ein Angreifer möchte wissen, ob zwei Nachrichten von derselben Person verschickt wurden.

Unverkettbarkeit wird auch als „Unverknüpfbarkeit" oder „Nicht-Verkettbarkeit" (engl. unlinkability) bezeichnet.

Linking Examples

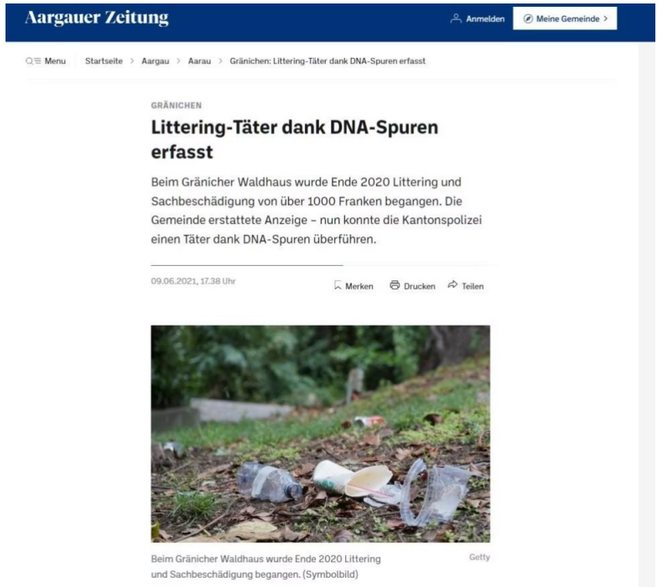


Fall

DNA Analyse

Woher stammen die Gegenproben? Was wurde verkettet?

Ende 2020 wurde im Gränicher Waldhaus Susten neben Littering auch Sachbeschädigung im Wert von über 1000 Franken begangen. Die Gemeinde erstattete Anzeige, und die Kantonspolizei konnte mithilfe von DNA-Spuren einen Täter für das Littering identifizieren. Die Sachbeschädigungen konnten jedoch nicht nachgewiesen werden. Die verantwortliche Person erhielt eine Busse von 300 Franken. Die Regionalpolizei Suret kontrolliert regelmässig Waldhäuser und Brötlistellen, besonders an Wochenenden und bei schönem Wetter, um gegen Sachbeschädigung und Littering vorzugehen.



https://www.aargauerzeitung.ch/aargau/aarau/littering-tater-dank-dna-spuren-erfasst-ld.2148275

DNA-Abgleich

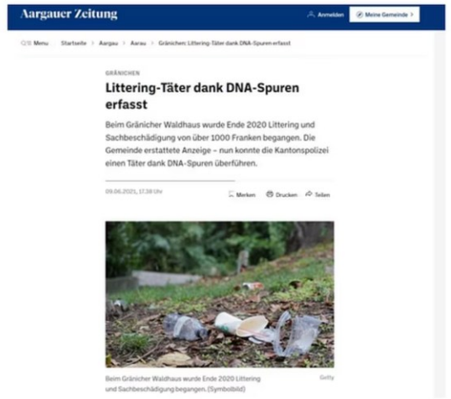
Abgleich der am Tatort gefundenen DNA-Spuren mit DNA-Proben in den Datenbanken

VERKETTUNG

Die Verkettung von DNA-Spuren vom Tatort mit bestehenden Datenbanken ermöglicht die Identifizierung von Verdächtigen.

DNA Analyse

Woher stammen die Gegenproben? Was wurde verkettet?


Aargauer Zeitung

GRÄNICHEN

Littering-Täter dank DNA-Spuren erfasst

Beim Gränicher Waldhaus wurde Ende 2020 Littering und Sachbeschädigung von über 1000 Franken begangen. Die Gemeinde erstattete Anzeige – nun konnte die Kantonspolizei einen Täter dank DNA-Spuren überführen.

Beim Gränicher Waldhaus wurde Ende 2020 Littering und Sachbeschädigung begangen. (Symbolbild)

„Dass beim Liegenlassen von Abfall gleich eine umfassende Ermittlung samt Sicherstellung von DNA-Spuren unternommen wird, dürfte eher selten sein. Da aber Ende 2020 im Gränicher Waldhaus Susten nebst Littering auch Sachbeschädigung im Rahmen von über 1000 Franken begangen wurde, erstattete die Gemeinde Anzeige. Die Lichtanlage ging kaputt und die Holzverkleidung der Hütte wurde zerkratzt.

Die Kantonspolizei konnte dank DNA-Spuren immerhin einen Täter überführen – aber nur bezüglich Littering. Den Rest konnte man ihm nicht nachweisen. Die in der Region wohnhafte Person erhielt eine Busse von 300 Franken. Die Regionalpolizei Suret kontrolliert laut Chef Thomas Zbinden «nach Möglichkeit tagtäglich sämtliche Waldhäuser und Brötlistellen», an Wochenenden und bei schönem Wetter noch intensiver. «Sachbeschädigungen und vor allem Littering ist ein sehr grosses Problem und wir kämpfen seit Jahren dagegen an.» *(dvi)*“

Datenschutz-Schutzziele

Intervenierbarkeit

Intervenierbarkeit: Verfahren sind so gestaltet werden, dass sie den Betroffenen die Ausübung der ihnen zustehenden Rechte (z. B. auf Auskunft, Berichtigung, Löschung etc.) wirksam ermöglichen.

Verantwortliche Stelle muss jederzeit in der Lage sein, in den Verarbeitungsprozess einzugreifen

Massnahmen:

Benutzerrechte

Differenzierte Einwilligungs- sowie Widerspruchsmöglichkeiten, Implementierung standardisierter Abfrage- und Dialogschnittstellen für Betroffene

Auf Datenebene

Sperr- und Widerspruchshinweise

Auf Systemebene

Sperrung einzelner Funktionalitäten und Systemkomponenten ohne Verlust des Gesamtsystems

Massnahmenkatalog am Beispiel

Praktische Anwendung der Schutzziele bei der **Datensicherung:**

Vertraulichkeit

Verschlüsselung der Daten

Verfügbarkeit

Haltbarkeit und Aufbewahrung von Datenträgern

Integrität

Schutz vor Manipulation des Backups

Transparenz

Dokumentation des Ablaufs der Datensicherung, der Verantwortlichkeiten, Protokollierungen von Sicherungen und Rückeinspielungen

Unverkettbarkeit

Keine zweckwidrige Nutzung

Intervenierbarkeit

Löschungsmöglichkeiten, Schutz vor versehentlicher Rückeinspielung

Probst, T. (2012). Generische Schutzmassnahmen für Datenschutz-Schutzzielehttps://www.maroki.de/pub/other/2012-06-DuD-SDMMassnahmen.pdf

Übung

Klassische Schutzziele der IT-Sicherheit stehen gelegentlich im Widerspruch zum Datenschutz – zeigen Sie einen solchen Zielkonflikt an einem konkreten Beispiel auf.

Stichworte für die Antwort

Verfügbarkeit vs. Datenschutz

Zielkonflikt: Replikation personenbezogener Daten auf globalen Servern.

Konfliktpunkt

IP-Adressen und andere Daten können in weniger datenschutzfreundlichen Ländern gespeichert werden.

Auswirkung

Datenschutz wird zugunsten der Verfügbarkeit beeinträchtigt.

Zusammenfassung

Identität

Die Menge aller Attributwerte, mit denen man von anderen unterschieden werden kann

Anonymität

Angreifer kann mich nicht mehr hinreichend genau identifizieren

Pseudonym

Ein Identifikator ungleich dem realen Namen

Unverkettbarkeit

Angreifer kann nicht hinreichend sicher feststellen, ob zwischen bestimmten Objekten eine Beziehung besteht oder nicht

Intervenierbarkeit

Bezieht sich darauf, Betroffenen die wirksame Ausübung ihrer Rechte zu ermöglichen

Nächste Vorlesung SW4

Thema

Web Tracking





Vielen Dank

Fragen und Diskussion sind herzlich willkommen